LABORATUVAR 6 · MAKİNEYE ÖZEL SÜRÜM · DRACHEN 2128 HYPER CNC ROUTER

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad: Emirhan Bayrak | Grup: Gündüz | Tarih: 06.11.2026

Senaryo: Saat **10:15**. Drachen 2128 Hyper'ın CNC PC'sinde, satıcının uzak servis hesabıyla yetkisiz erişim tespit edildi. CNC yazılım ayarları ile servo sürücü / spindle inverter parametreleri değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1

10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Kimi ararım: Bakım / otomasyon sorumlusu, BT-OT güvenlik sorumlusu, İSG uzmanı ve üretim müdürü. Satıcı (Türkoğlu Makine) aranarak 10:15'teki bağlantının kendi teknisyenlerine ait olup olmadığı sorulur.

- **1. Makineyi güvenli şekilde durdur:** Program kontrollü olarak durdurulur, spindle'ın tamamen durduğu gözle teyit edilir, kimse tabla bölgesine girmez. Parametreler değişmiş olabileceği için makineye güvenilmez. Makinenin enerjisi kesilmez, CNC PC kapatılmaz.
- **2. Saldırganın erişimini kes:** CNC PC'nin ağ kablosu çekilir veya güvenlik duvarında bağlantısı kapatılır; uzak erişim yazılımı devre dışı bırakılır.
- **3. Olay kaydını başlat:** Saat, kim neyi gördü, ekranda ne vardı; ekran fotoğrafları çekilir. Hiçbir ayar "düzeltilmez", hiçbir şey silinmez.

2

İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

- **Emniyet güvende mi:** Önce kanıt alınır, sonra makine boşken acil stop, Z freni, spindle duruş süresi ve kişi algılama fonksiyon testleri yapılır. Servo sürücü ve inverter parametreleri son onaylı yedekle karşılaştırılır. Bu kontroller bitmeden makine üretime alınmaz.
- **Korunan kanıtlar:** CNC PC'nin disk imajı (ve mümkünse bellek dökümü), uzak erişim yazılımının bağlantı kayıtları, Windows olay günlükleri, güvenlik duvarı / modem kayıtları, CNC yazılımının alarm ve olay geçmişi, sürücü ve inverter parametre dökümleri, son yüklenen G-kodu dosyaları ve tarihleri. Her kanıtın özet değeri (hash) alınır ve kimin aldığı yazılır.
- **Kapatılan hesap:** Ele geçirilen paylaşılan servis hesabı hemen devre dışı bırakılır. Aynı parolanın kullanıldığı tüm hesapların parolaları değiştirilir; satıcıdan teknisyen hesaplarını kişiselleştirmesi istenir.

3 **24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?**

CRA'da bildirim yükümlülüğü ürünün **üreticisindedir**; işletme olarak görevimiz, üreticinin bildirimi yapabilmesi için ona bilgiyi hızla iletmektir. Hazır olması gerekenler:

- Etkilenen ürün: Drachen 2128 Hyper, CNC yazılımı ve firmware sürümleri.
- Olayın ilk tespit zamanı ve kısa tanımı: servis hesabıyla yetkisiz uzak erişim, parametre değişikliği şüphesi.
- Olayın kötü niyetli bir eylemden kaynaklandığına dair şüphe ve dayanağı.
- Aynı makineyi kullanan başka işletmelerin veya ülkelerin etkilenme ihtimali (aynı servis hesabı başka müşterilerde de kullanılıyor olabilir).
- Şu ana kadar alınan önlemler: makine durduruldu, erişim kesildi, hesap kapatıldı.

4 **72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?**

- **Kök neden:** Tüm teknisyenlerin ortak kullandığı, MFA'sız servis hesabının parolası ele geçirildi; CNC PC'deki uzak masaüstü yazılımı sürekli açıktı.
- **Etki:** Hangi parametrelerin değiştiği (örneğin spindle duruş rampası, Z fren gecikmesi), emniyet fonksiyonlarının etkilenip etkilenmediği, üretim kaybı, yaralanma olup olmadığı.
- **Önlem:** Parametreler onaylı yedekten geri yüklendi ve fonksiyon testleri yapıldı; uzak erişim jump server + VPN + MFA + kişisel hesap ile yeniden kuruluyor.
- **Kim ne yapıyor:** BT-OT güvenlik sorumlusu teknik analizi ve kanıt incelemesini yürütür. Bakım ekibi parametreleri geri yükler ve testleri yapar. İSG uzmanı emniyetin doğrulandığını onaylar. Yönetim ve hukuk iletişimi ve yasal süreçleri yönetir. Üretici zafiyeti analiz eder, yetkili otoriteye bildirimi yapar ve diğer müşterilerini uyarır.

5 **14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?**

- Uzak erişim yazılımı, VPN ve güvenlik duvarı bağlantı kayıtları.
- CNC PC'nin Windows güvenlik ve sistem olay günlükleri, disk imajı ve özet değerleri.
- CNC yazılımının alarm / olay geçmişi ve son yüklenen G-kodu dosyaları.
- Servo sürücü ve inverter parametrelerinin olay öncesi, olay anı ve geri yükleme sonrası dökümleri.
- Emniyet fonksiyon testlerinin kayıtları ve imzaları.
- Vardiya / olay defteri, dakika dakika zaman çizelgesi ve satıcıyla yapılan yazışmalar.
- Alınan düzeltici önlemlerin ve yeniden üretime alma onayının kaydı.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

Kaynaklar: EU 2024/2847 Siber Dayanıklılık Yasası (CRA), Madde 14 (bildirim yükümlülükleri) · IEC 62443-2-1 (olay müdahalesi) · EN ISO 13849-2 (doğrulama).